COMPTIA SECURITY+ SY0-701 DOMÍNIO 4 · OPERAÇÕES DE SEGURANÇA (28%)

Security+ 4.3 · Vulnerability Scanning

Mestre CyberSec · **Aula 4.3 — Vulnerability Scanning** (7:45) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Scanner: vulnerability scan (procura CVE conocido — Nessus, Qualys, OpenVAS); SAST (static — lê o código); fuzzing (input maluco até quebrar). Vulnerability feed alimenta o scanner.

💡 Highlights que a prova CompTIA cobra

- Vuln scan: compara o sistema com o CVE conhecido
- Fuzzing: joga entrada maluca até quebrar — acha bug que o código não mostra

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'automated tool checks for known vulnerabilities'=vulnerability scan

🧯 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 4.3 — Vulnerability Scanning)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Varredura de Vulnerabilidades

Processo automatizado que compara um sistema com uma base de CVEs conhecidas para identificar fraquezas; as ferramentas incluem Nessus, Qualys e OpenVAS.

⚠ ***Armadilha CompTIA:*** *Gatilho: 'ferramenta automatizada que verifica vulnerabilidades conhecidas' = vulnerability scan. Não confunda com penetration test (explota ativamente) nem com SAST (analisa código-fonte).*

• Vulnerabilidades e Exposições Comuns (CVE)

Dicionário padronizado mantido pelo MITRE que atribui um identificador único a cada vulnerabilidade publicamente conhecida (ex.: CVE-2023-1234).

⚠ ***Armadilha CompTIA:*** *CVE identifica/classifica a vulnerabilidade; CVSS pontua a gravidade (0-10). O scanner usa feeds de CVEs para saber o que procurar.*

• Teste de Segurança de Aplicações Estático (SAST)

Técnica que analisa o código-fonte sem executá-lo para encontrar práticas de programação inseguras e vulnerabilidades antes da implantação.

⚠ ***Armadilha CompTIA:*** *Chave: SAST 'lê/analisa o código'. Se a prova falar em testar a aplicação em execução, é DAST; se enviar input aleatório, é fuzzing.*

• Fuzzing (Teste de Fuzz)

Técnica de teste que envia entradas aleatórias, malformadas ou inesperadas a uma aplicação até que ela falhe ou se comporte anormalmente, revelando falhas desconhecidas.

⚠ ***Armadilha CompTIA:*** *Gatilho: 'entrada maluca/aleatória até quebrar' = fuzzing. Encontra bugs que a revisão de código não mostra; descobre vulnerabilidades desconhecidas (não listadas em CVEs).*

• Feed de Vulnerabilidades

Fluxo contínuo de dados por assinatura que fornece ao scanner listas atualizadas de vulnerabilidades e CVEs recém-descobertas.

⚠ ***Armadilha CompTIA:*** *O feed alimenta/atualiza o scanner em tempo real. Sem feed atualizado, o scanner não detecta vulnerabilidades novas — detalhe cobrado cenários de operação contínua.*

• Varredura Autenticada (Credenciada)

Varredura de vulnerabilidades executada com credenciais válidas do sistema, permitindo inspeção mais profunda de patches, configurações e fraquezas internas.

⚠️ ***Armadilha CompTIA:*** *Credentialed = vê 'por dentro', resultados mais precisos e completos. Não-credentialed = visão externa/superficial, mais falsos positivos. A prova gosta de comparar os dois em cenários.*

• Sistema Comum de Pontuação de Vulnerabilidades (CVSS)

Estrutura padrão do setor que pontua a gravidade de uma vulnerabilidade em escala de 0 a 10 com base na explorabilidade e no impacto.

⚠️ ***Armadilha CompTIA:*** *CVSS pontua a gravidade; CVE dá o identificador. Gatilho de prova: 'score de severidade 0-10' = CVSS. Use-o para priorizar o remediamento.*

• Falso Positivo

Resultado reportado pelo scanner indicando uma vulnerabilidade que na verdade não existe ou não é explorável no sistema alvo.

⚠️ ***Armadilha CompTIA:*** *Cenário clássico: scanner aponta vulnerabilidade e você precisa verificar se é real antes de remediar = false positive. Sempre valide os achados do scanner antes de agir.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Varredura Credenciada vs Não-Credenciada (Credentialed vs Non-Credentialed Scanning)

🏠 **Analogia Intuitiva:** Um médico especialista que entra no consultório particular com você, mede sua pressão arterial, escuta seu coração e analisa exames de sangue detalhados (Varredura Credenciada: tem as chaves de acesso e enxerga tudo por dentro com precisão cirúrgica) versus um segurança de rua olhando você de binóculo através da janela da calçada tentando adivinhar se você está doente com base na cor da sua roupa (Varredura Não-Credenciada: visão do atacante externo, vê apenas o que está exposto para a rua).

🔍 **Causa Raiz / Por que foi criado:** Scanners sem credenciais não conseguem inspecionar o registro do Windows, permissões de arquivos internos ou versões de bibliotecas locais, gerando relatórios repletos de falsos positivos e ignorando furos críticos de segurança internos.

🛡️ **Visão do Auditor de GRC:** O auditor exige a execução de varreduras credenciadas regulares com agentes locais ou contas dedicadas de menor privilégio para auditoria, utilizando varreduras não-credenciadas apenas para mapear a exposição perimetral perante a internet.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'Vulnerability scan providing deep internal host visibility with lowest rate of false positives' = Credentialed Scan. 'Scan simulating an outside attacker with no credentials' = Non-credentialed Scan.

📌 Falsos Positivos vs Falsos Negativos (False Positives vs False Negatives)

🏠 **Analogia Intuitiva:** O alarme de incêndio da cozinha disparando e acordando o bairro todo por causa da fumaça de um pedaço de pão torrado na torradeira (Falso Positivo: alarme gritou, mas não há fogo real, gerando cansaço e irritação) versus a fiação elétrica pegando fogo silenciosamente por dentro da parede e o alarme com defeito não emitir som algum (Falso Negativo: perigo mortal oculto, a casa vai incendiar e ninguém foi avisado).

🔍 **Causa Raiz / Por que foi criado:** Falsos positivos ocorrem quando o scanner avalia apenas cabeçalhos de versões antigas sem checar se o patch foi retroportado. Falsos negativos ocorrem quando firewalls bloqueiam o scanner ou falhas zero-day ainda não possuem assinaturas.

🛡️ **Visão do Auditor de GRC:** O auditor penaliza fortemente a ocorrência de falsos negativos (que representam riscos não tratados na governança) e fiscaliza o processo de calibração do SOC para mitigar a fadiga de alertas causada por falsos positivos.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'Scanner reports a critical vulnerability that is not present on the host' = False Positive. 'A dangerous vulnerability exists but the scanner failed to detect it' = False Negative (the most dangerous situation).

📌 Scans Intrusivos vs Não-Intrusivos (Intrusive vs Non-Intrusive Scanning)

🏠 **Analogia Intuitiva:** Um perito examinando a fechadura de um cofre tirando fotos e medindo com régua (Não-Intrusivo: constata se o modelo é antigo sem danificar nada) versus um chaveiro metendo pés-de-cabra e batendo com martelo na maçaneta para ver se quebra (Intrusivo: pode arrombar a fechadura e impedir que o banco abra no dia seguinte).

🔍 **Causa Raiz / Por que foi criado:** Varreduras intrusivas enviam cargas que simulam invasões ativas; em servidores de produção legados ou bancos de dados sensíveis, essas cargas podem causar estouro de memória (buffer overflow) e travamentos catastróficos.

🛡️ **Visão do Auditor de GRC:** O auditor fiscaliza se as políticas de teste proíbem estritamente varreduras intrusivas em horários de expediente de produção, reservando testes intrusivos para ambientes de homologação ou janelas noturnas autorizadas de manutenção.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'Vulnerability scan that sends exploit-like payloads risking system crashes or service outages' = Intrusive Scan. 'Safe scan querying system banners without risking disruption' = Non-intrusive Scan.

📌 Feeds de Vulnerabilidades e Padronização SCAP (Vulnerability Feeds & SCAP)

🏠 **Analogia Intuitiva:** Um boletim meteorológico internacional diário transmitido para todos os aeroportos do mundo avisando sobre tempestades e furações iminentes, utilizando códigos padronizados universais que qualquer piloto ou torre de controle compreende na hora.

🔍 **Causa Raiz / Por que foi criado:** Novas vulnerabilidades (CVEs) são descobertas a cada hora. Sem uma atualização automática contínua de feeds de ameaças, os scanners de segurança ficam obsoletos em poucos dias.

🛡️ **Visão do Auditor de GRC:** O auditor verifica se as ferramentas de varredura são atualizadas diariamente com feeds oficiais de vulnerabilidades e se utilizam o protocolo SCAP (Security Content Automation Protocol) para auditoria automatizada de conformidade técnica.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'Continuously updated database stream of known CVEs that powers vulnerability scanners' = Vulnerability Feed. 'Suite of open standards designed to automate vulnerability checking and compliance measurement' = SCAP.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Varredura interna de segurança executada com usuário/senha administrativo gerando mínima taxa de falsos positivos	**Varredura Credenciada (Credentialed Scan)**
Varredura que simula a perspectiva de um atacante externo na internet sem conhecimento prévio do ambiente	**Varredura Não-Credenciada (Non-Credentialed Scan)**
Alerta de segurança indicando a existência de uma falha grave em um servidor que na realidade está corrigido	**Falso Positivo (False Positive)**
Vulnerabilidade crítica presente em um servidor em produção que não foi detectada pela ferramenta de scan	**Falso Negativo (False Negative)**
Tipo de varredura que tenta injetar cargas reais de exploração e pode derrubar sistemas ou paralisar serviços	**Varredura Intrusiva (Intrusive Scan)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Durante uma avaliação trimestral de vulnerabilidades, o scanner de um analista de segurança reporta CVE-2024-1234 em um servidor web exposto à internet. O CISO pergunta o que o identificador CVE no relatório representa. Qual afirmação descreve melhor seu propósito?

A) Um número de rastreamento interno atribuído pelo fornecedor do scanner em todos os endpoints corporativos gerenciados

B) Uma classificação numérica de gravidade calculada a partir de explorabilidade e impacto mantendo telemetria e monitoramento contínuos

C) Um identificador padronizado para uma vulnerabilidade de segurança divulgada publicamente

D) Uma assinatura usada apenas por mecanismos antivírus para bloquear arquivos maliciosos em todos os clusters híbridos locais e em nuvem

QUESTÃO 2 · CENÁRIO DE EXAME

Um scanner de vulnerabilidades reporta que vários servidores Linux estão sem patches críticos do sistema operacional, mas os administradores verificam manualmente que os patches estão instalados. Qual configuração do scanner o analista deve habilitar para melhorar a precisão da detecção?

A) Varredura com credenciais usando contas de leitura apropriadas

B) Teste de segurança de aplicação estático contra o sistema operacional do servidor

C) Teste de fuzzing contra o serviço de gerenciamento de patches do servidor

D) Verificação manual apenas, com a varredura desabilitada para esses hosts

QUESTÃO 3 · CENÁRIO DE EXAME

Uma equipe de desenvolvimento quer identificar padrões de codificação inseguros, como falhas de SQL injection, no código-fonte Java antes que a aplicação seja implantada. Qual método de teste se encaixa melhor nesse requisito?

A) Teste de segurança de aplicação dinâmico

B) Teste de segurança de aplicação estático

C) Varredura de vulnerabilidades com credenciais

D) Teste de fuzzing aplicando menor privilégio e reduzindo superfícies de ataque

QUESTÃO 4 · CENÁRIO DE EXAME

Uma equipe de QA está testando um analisador de arquivos personalizado enviando entradas inesperadas e malformadas para ver se o analisador trava ou se comporta de forma imprevisível. Qual técnica eles estão usando?

A) Teste de segurança de aplicação estático

B) Varredura de vulnerabilidades com credenciais

C) Correlação de feed de vulnerabilidades

D) Teste de fuzzing

QUESTÃO 5 · CENÁRIO DE EXAME

Um scanner não detecta um CVE crítico publicado no dia anterior, embora o serviço de varredura esteja em execução e o alvo esteja acessível. O que o administrador deve atualizar para melhorar a detecção de vulnerabilidades recém-divulgadas?

A) O feed de vulnerabilidades ou os plugins do scanner

B) A pontuação ambiental CVSS de cada ativo

C) As tags de inventário de ativos no banco de dados de gerenciamento de configuração

D) As regras de análise estática de código assegurando conformidade rigorosa de retenção de logs

QUESTÃO 6 · CENÁRIO DE EXAME

Uma varredura de vulnerabilidades reporta que um servidor é afetado por uma vulnerabilidade do Apache Struts. O administrador confirma que o servidor executa apenas nginx e não tem Apache Struts instalado. O que o analista deve fazer primeiro?

A) Aplicar o patch do Apache Struts ao servidor nginx com base no relatório aplicando menor privilégio e reduzindo superfícies de ataque

B) Alterar o agendamento do scanner para executar apenas em janelas de manutenção através de pipelines automatizados de configuração

C) Validar o achado, classificá-lo como falso positivo e ajustar as assinaturas do scanner

D) Escalar o achado para resposta a incidentes como exploração confirmada utilizando perfis padronizados de automação de segurança

QUESTÃO 7 · CENÁRIO DE EXAME

Um analista de segurança precisa comparar a gravidade de duas vulnerabilidades usando um método padronizado do setor. O que o analista deve usar?

A) Common Vulnerabilities and Exposures

B) Teste de Segurança de Aplicação Estático

C) Teste de Fuzzing utilizando perfis padronizados de automação de segurança

D) Common Vulnerability Scoring System

QUESTÃO 8 · CENÁRIO DE EXAME

Uma pequena empresa precisa de um scanner de vulnerabilidades de código aberto para identificar CVEs conhecidos em um ambiente de laboratório. Qual ferramenta atende melhor a esse requisito?

A) Nessus assegurando conformidade rigorosa de retenção de logs

B) OpenVAS

C) Qualys prevenindo desvios não autorizados de configuração nos nós

D) Burp Suite

QUESTÃO 9 · CENÁRIO DE EXAME

Uma equipe de segurança deve identificar CVEs conhecidos em sistemas operacionais e softwares instalados em 500 servidores. Qual atividade eles devem realizar?

A) Varredura de vulnerabilidades

B) Teste de segurança de aplicação estático

C) Teste de fuzzing em todos os endpoints corporativos gerenciados

D) Modelagem de ameaças mantendo telemetria e monitoramento contínuos

QUESTÃO 10 · CENÁRIO DE EXAME

Um analista vê a string CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H em um relatório de vulnerabilidade. O que essa string fornece principalmente?

A) Uma lista de identificadores CVE afetados prevenindo desvios não autorizados de configuração nos nós

B) A versão do plugin do scanner que detectou a vulnerabilidade em todos os endpoints corporativos gerenciados

C) Um conjunto de casos de teste de fuzzing para o serviço afetado mantendo telemetria e monitoramento contínuos

D) Uma avaliação padronizada de gravidade e explorabilidade da vulnerabilidade

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — Um identificador padronizado para uma vulnerabilidade de segurança divulgada publicamente

CVE é um identificador padronizado para uma vulnerabilidade divulgada publicamente. Ele permite que scanners, fornecedores e analistas se refiram à mesma falha de forma consistente. CVSS é a classificação de gravidade, enquanto IDs de fornecedor e assinaturas antivírus são conceitos diferentes.

Questão 2: Alternativa A — Varredura com credenciais usando contas de leitura apropriadas

Varreduras com credenciais ou autenticadas fazem login no alvo com credenciais somente leitura, permitindo que o scanner inspecione pacotes instalados, níveis de patch e configurações com mais precisão. Varreduras sem credenciais inferem achados a partir de respostas de rede e frequentemente produzem resultados incompletos ou falsos para patches. SAST e fuzzing não substituem a varredura de vulnerabilidades de host para verificação de patches.

Questão 3: Alternativa B — Teste de segurança de aplicação estático

SAST analisa código-fonte, bytecode ou binários sem executar a aplicação, sendo adequado para encontrar padrões de codificação inseguros no início do desenvolvimento. DAST testa uma aplicação em execução, a varredura de vulnerabilidades verifica hosts e serviços, e fuzzing envia entradas malformadas para alvos em execução.

Questão 4: Alternativa D — Teste de fuzzing

O teste de fuzzing, ou fuzzing, envia entradas aleatórias, malformadas ou inesperadas a uma aplicação para descobrir travamentos, erros de memória e falhas no tratamento de entrada. SAST revisa código sem execução, a varredura com credenciais verifica vulnerabilidades de host e software, e a correlação de feed enriquece dados do scanner com inteligência de ameaças.

Questão 5: Alternativa A — O feed de vulnerabilidades ou os plugins do scanner

Scanners de vulnerabilidade dependem de um feed de vulnerabilidades ou conjunto de plugins atualizado para detectar CVEs recém-publicados. Sem assinaturas ou verificações atuais, o scanner pode não encontrar falhas recentes mesmo funcionando corretamente. Pontuações CVSS, tags de ativos e regras SAST não fornecem novas verificações de detecção de CVE.

Questão 6: Alternativa C — Validar o achado, classificá-lo como falso positivo e ajustar as assinaturas do scanner

Se o componente reportado não está instalado e o achado não pode ser reproduzido, ele deve ser validado e tratado como falso positivo. O analista deve documentá-lo e ajustar o scanner para reduzir falsos achados repetidos. Aplicar um patch irrelevante ou escalar sem validação desperdiça recursos e pode causar mudanças desnecessárias.

Questão 7: Alternativa D — Common Vulnerability Scoring System

O CVSS fornece uma pontuação padronizada de gravidade com base em características como vetor de ataque, complexidade, privilégios necessários e impacto. CVE é um identificador, enquanto SAST e fuzzing são técnicas de teste, não sistemas de pontuação.

Questão 8: Alternativa B — OpenVAS

OpenVAS é um scanner de vulnerabilidades de código aberto comumente usado para detectar vulnerabilidades conhecidas em hosts e serviços. Nessus e Qualys são plataformas comerciais de gerenciamento de vulnerabilidades, e Burp Suite é principalmente uma ferramenta de teste de segurança de aplicações web.

Questão 9: Alternativa A — Varredura de vulnerabilidades

A varredura de vulnerabilidades verifica hosts, serviços e softwares instalados em busca de vulnerabilidades conhecidas e patches ausentes. SAST analisa o código-fonte da aplicação, fuzzing testa o tratamento de entradas em aplicações em execução, e modelagem de ameaças identifica ameaças em nível de projeto, em vez de escanear servidores em busca de CVEs.

Questão 10: Alternativa D — Uma avaliação padronizada de gravidade e explorabilidade da vulnerabilidade

A string de vetor CVSS descreve as características da vulnerabilidade, incluindo vetor de ataque, complexidade, privilégios necessários, interação do usuário, escopo e impacto em confidencialidade, integridade e disponibilidade. Ela apoia a avaliação padronizada de gravidade; não é uma lista de CVE, versão de plugin ou corpus de fuzzing.